



UNIVERSIDADE SÃO TOMÁS DE MOÇAMBIQUE

Faculty of Computer Science

RESEARCH PROPOSAL

**An Automated Analysis of HTTP Security Header Implementation
Across Popular Websites: Identifying Common Misconfigurations and
Gaps in Web Security Posture**

Prepared by:

Anayo Chibuike Anyafulu

Third-Year Computer Science Student

Course: Research Methodology (RM_2026-ii)

*Submission of the Proposal on Specific Study Theme: Outlines, Literature Review, Contextualization, Methods, Problem Statement,
Research Question(s), Objectives, Problem Analysis, Hypothesis and Prototype*

Maputo, Mozambique — September 2026

1. Outline of the Study

This proposed study will measure how well popular and nationally significant websites implement HTTP security headers, the small configuration directives a web server sends with every response to instruct browsers how to protect its content. When correctly configured, these headers form a first line of defence against some of the most common web attacks: Content-Security-Policy (CSP) restricts what scripts and content a browser may load and thereby blunts cross-site scripting (XSS); Strict-Transport-Security (HSTS) forces encrypted HTTPS connections and defeats protocol downgrade and man-in-the-middle attacks; X-Frame-Options blocks clickjacking; X-Content-Type-Options prevents dangerous MIME-type sniffing; Referrer-Policy controls leakage of browsing history to third parties; and Permissions-Policy restricts which powerful browser features a page may invoke.

Despite being cheap, standards-based and widely recommended, these headers are frequently absent or misconfigured. The proposed study will scan a purposive sample of approximately one hundred websites — roughly sixty Mozambican sites drawn from government, banking and insurance, higher education, and major commercial organisations, and forty international sites in the same categories for comparison — using a custom, open-source scanner. Each of the six headers will be classified as correctly configured, present but weak, or missing, producing a 0–100 security header score per site. The analysis will compare adoption across headers, across sectors, and between Mozambican and global sites, and will test whether observed differences are statistically significant.

The study makes three contributions. First, it will produce the first independent, methodologically transparent measurement of security header deployment for Mozambican websites, a population absent from the existing literature. Second, it will quantify the most common misconfigurations so that site owners and regulators can prioritise remediation. Third, it will deliver a reusable, fully open-source scanning and analysis pipeline, so that the measurement can be repeated over time by anyone. A working prototype of this pipeline is described in Section 10; the study itself will refine the prototype, extend the sample, and report the findings.

2. Literature Review

The research literature and industry reports establish both the value of HTTP security headers and the persistent gap between recommendation and practice.

Headers and the threats they address. The foundational standards document the intent of each mechanism. Hodges, Jackson and Barth (2012) specified HSTS (RFC 6797), which allows a server to declare that browsers must contact it only over HTTPS, closing the door on SSL-stripping and cookie-hijacking attacks that exploit user habits of typing bare domain names. CSP, introduced by the W3C and maintained in the HTML and Fetch standards, was designed as a defence-in-depth mechanism against XSS, the most prevalent class of web vulnerabilities (MDN Web Docs, 2025). Framing protections such as X-Frame-Options and the newer CSP frame-ancestors directive address clickjacking, in which a victim is tricked into interacting with a hidden or disguised page. Supporting headers such as X-Content-Type-Options, Referrer-Policy and Permissions-Policy close secondary but real attack surfaces: MIME confusion, referrer leakage, and abuse of powerful browser APIs such as camera, geolocation and payment interfaces (OWASP Foundation, 2025).

Large-scale measurement studies. Empirical work has repeatedly shown that adoption is uneven and often superficial. Lavrenovs and Rubio Melón (2018) scanned the top one million websites and found that only a minority deployed the most protective headers at all, with HSTS adoption concentrated among the very largest domains. Earlier and contemporaneous work reported similar patterns for individual headers, and

commercial scanning services such as securityheaders.com (Helme, 2024) and the Mozilla Observatory continue to report that a large share of popular sites score poorly on header security.

Quality, not just presence. Presence of a header does not guarantee protection. Weichselbaum, Spagnuolo, Lekies and Janc (2017), in the largest study of CSP deployment to date, analysed roughly 1.6 million CSP policies and found that about 95% were not effective against XSS, most commonly because they used allow-list configurations containing script sources that can be bypassed, such as domains that host unsafe content, or directives permitting inline scripts (`unsafe-inline`). This finding motivates a central design decision of the proposed study: headers must be graded not merely as present or absent, but as correctly configured versus weakly configured. Similarly, Calzavara, Rabitti, Roth and Backes (2020) formally analysed framing control and documented inconsistencies in how browsers interpret X-Frame-Options and CSP frame-ancestors, showing that even well-intentioned configurations can fail in practice.

Annual industry measurements. The HTTP Archive's annual Web Almanac has tracked security header adoption across millions of sites since 2019, reporting steady year-on-year growth in CSP and Permissions-Policy usage among the top sites, while noting that the long tail of the web — including most sites outside Western markets — remains far behind (HTTP Archive, 2022). These reports, however, are aggregations dominated by globally popular domains; they cannot answer how a specific national population of sites is protected.

The research gap. Three gaps emerge. First, a *geographic gap*: published measurements overwhelmingly cover global or Western European and North American sites; no published, peer-visible study documents header security for Mozambican domains, and African coverage generally is sparse. Second, a *transparency gap*: much existing data is produced by commercial scanning products whose classification rules and scoring are not fully disclosed, limiting scholarly scrutiny. Third, a *reproducibility gap*: few studies publish both their site lists and their tooling, so findings cannot be repeated to track change over time. The proposed study addresses all three: it targets an undocumented national population, uses a fully disclosed scoring rubric, and ships an open-source pipeline.

3. Contextualization

Mozambique's digital economy is expanding quickly. Citizens increasingly interact with government portals for taxation, identity and public services; banks and mobile-money providers have made digital channels the primary interface for millions of customers; and universities deliver content and administration online. Each of these interactions is a potential target: XSS can be used to steal session cookies or defraud users inside trusted sites, clickjacking can trick customers into unintended financial actions, and unencrypted or downgradeable connections expose credentials on shared and mobile networks that are common in the region.

At the same time, cybersecurity capacity is still maturing. The International Telecommunication Union's Global Cybersecurity Index places Mozambique among the developing cybersecurity commitments in the region (International Telecommunication Union, 2024), and security operations resources at individual organisations remain limited. In this context, HTTP security headers have a particular appeal: they cost nothing to deploy, require no new infrastructure, and deliver immediate, measurable risk reduction. Yet precisely because they are invisible, they are easy to neglect — and there is no local, public data telling organisations where they stand.

The study is situated at the Faculty of Computer Science, Universidade São Tomás de Moçambique, whose own web presence falls within the population to be scanned. By pairing a Mozambican sample with an international comparison group drawn from the same sectors, the study will distinguish problems that are global (weak CSP is everywhere) from problems that are local (entirely unreachable government domains), and will give Mozambican institutions an evidence-based benchmark. The results are intended to be directly usable by three audiences: website administrators who need a remediation checklist, university instructors who need a live, local case study for web security teaching, and policymakers who need baseline data before considering national guidance on baseline web protections.

4. Methodology

Design. The study will be a quantitative, non-intrusive measurement study of HTTP response headers, cross-sectional in nature: a single scan window from which all rates are reported.

Population and sampling. The sampling frame will be documented in a public site list (sites.csv) containing the site name, URL, category and region for each entry. Approximately 100 sites will be sampled purposively — not randomly — to include the organisations citizens actually use. The Mozambican sample (about 60 sites) will comprise: (a) government ministries, agencies and the national portal (.gov.mz); (b) banks, insurers and the social security institute; (c) public and private universities (.ac.mz); and (d) major commercial companies in telecommunications, media, energy, transport and retail. The global comparison set (about 40 sites) will include top-ranked international sites in the same four categories (for example, leading global banks, government portals such as GOV.UK, major universities and high-traffic commercial platforms). Purposive sampling is appropriate because the research questions concern the security posture of the most-used services rather than the average of all registered domains; the limitation this imposes is acknowledged in Section 8.

Instrument and data collection. A custom scanner will be built in Python using the requests library. For each site it will: issue one HTTPS GET request with a custom User-Agent identifying the academic study; follow redirects to the final destination; apply a 10-second timeout with one retry on transient errors; and record every response header, the final URL, redirect status, HTTP status and any connection error into a raw CSV dataset. Scanning will run with modest concurrency (about eight workers) and fixed randomised ordering to be gentle on target servers. Connection failures will be retained and classified (DNS failure, TLS certificate failure, timeout, other), because unreachability is itself a security-relevant finding for a national web population.

Headers and scoring. Six headers will be assessed: CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy and Permissions-Policy. Each header contributes one sixth of a site's 0–100 score: fully correct configuration earns full credit; a present-but-weak configuration earns half credit; absence earns zero. Classification rules will be published in full in the analysis code. Illustratively: a CSP containing unsafe-inline or unsafe-eval is weak; HSTS with max-age below one year (31536000 seconds) or lacking includeSubDomains is weak; X-Frame-Options with the obsolete ALLOW-FROM value is weak; and any of the six headers absent from the final response is missing.

Data analysis. For RQ1 and RQ2 the study will compute per-header presence, correct-configuration and weakness rates, and rank headers by correct-configuration rate. For RQ3 it will compute category-level mean scores and run chi-square tests of independence (correct versus not correct) across the four categories for each header, at a significance level of $\alpha = 0.05$. For RQ4 it will report the mean score overall and by region and category. Region-level comparison (MZ versus global) will use the same descriptive approach.

All analysis will be scripted, and both the raw dataset and the computed analysis file will be published.

Ethics. The study performs only passive observation of publicly served HTTP response headers — one GET request per site, no exploitation, no login, no personal data collection, and no attempts to bypass protections. User-Agent identification and conservative request rates follow responsible scanning practice. No individual site will be named in a way that alleges a vulnerability beyond the objective header facts recorded; findings will be reported at aggregate level, with the per-site dataset available for replication.

Validity and reliability. Internal validity is served by deterministic, published classification rules and by storing raw headers so every verdict is auditable. External validity is bounded: the sample describes the sampled sites, not all .mz domains. Reliability is served by recording the scan date and network location, and by making the entire pipeline reproducible from a clean machine with three commands.

5. Problem Statement

HTTP security headers are among the cheapest, highest-leverage defences available to any website operator, and their value is documented in both standards and empirical research. Yet deployments remain inconsistent, and misconfiguration — a present header that protects nothing — is as common as absence. For Mozambican websites the problem is compounded by an absence of evidence: no independent, reproducible measurement of header security for .mz domains exists in the literature, so organisations cannot benchmark themselves, educators lack local case material, and policymakers have no baseline against which to set guidance.

Three specific gaps sustain this problem. First, an *evidence gap*: existing measurements are dominated by global top-domain populations (Lavrenovs & Rubio Melón, 2018; HTTP Archive, 2022) that say little about nationally significant sites. Second, a *transparency gap*: commercial scanners produce scores whose classification rules are not fully public, so the numbers cannot be independently scrutinised. Third, a *reproducibility gap*: without published tooling and site lists, no one can repeat a measurement to verify it or track improvement. The consequence is a defence that everyone can afford and no one in Mozambique can currently verify. This study will close that gap for a documented sample of Mozambican and comparable international websites.

6. Research Questions

Primary research question: How well do popular and nationally significant websites implement recommended HTTP security headers, and what are the most common gaps or misconfigurations?

Sub-questions:

- RQ1. What percentage of sampled websites implement each of the six key security headers correctly?
- RQ2. Which header is most commonly missing or misconfigured across the sample?
- RQ3. Are there statistically significant differences in header implementation across website categories (government, financial, educational, commercial)?
- RQ4. What is the average security header score across the sample, and how does the Mozambican subset compare with the global comparison set?

7. Objectives

General objective: to measure and compare the implementation quality of six HTTP security headers across a purposive sample of approximately 100 Mozambican and international websites, using a transparent, reproducible methodology.

Specific objectives:

1. To quantify the presence and correct-configuration rate of CSP, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy and Permissions-Policy across the sample (addresses RQ1).
2. To rank headers by correct-configuration rate and catalogue the most frequent weak configurations (addresses RQ2).
3. To compare header implementation across the four website categories using descriptive statistics and chi-square tests of independence (addresses RQ3).
4. To compute a 0–100 security header score per site and report mean scores overall, by region and by category (addresses RQ4).
5. To design, build and validate an open-source scanning, analysis and reporting pipeline that makes the study fully reproducible (deliverable objective).
6. To derive prioritised, evidence-based remediation recommendations for website administrators and policymakers in Mozambique (application objective).

8. Problem Analysis

Why do well-meaning organisations leave these defences switched off? The analysis proposed here identifies five compounding root causes, each of which the study's outputs will address.

Unawareness. Headers are invisible to end users and to management dashboards focused on uptime and design. Many administrators have simply never been shown the gap. The study's per-category benchmarks give administrators a concrete, local reference point rather than abstract advice.

Misconfiguration through frameworks. Even motivated teams often ship weak headers because a framework, CDN or hosting panel emits a default: a CSP with unsafe-inline, an HSTS policy with a short max-age, an obsolete X-Frame-Options value. Section 4's three-way classification (correct, weak, missing) exists precisely to expose these silent failures, which a presence/absence audit would miss.

Fear of breakage. Strict CSP in particular can break embedded scripts and third-party widgets, so teams disable it. Documenting what the most common weak configurations look like in practice helps teams understand that partial deployment — report-only mode, then incremental tightening — is a viable path.

No local mandate or benchmark. In markets with mature regulation, public-sector baseline guidance has accelerated header adoption. No Mozambican baseline data currently exists to inform such guidance; this study supplies the missing baseline and can be re-run longitudinally to measure any policy effect.

Perceived tooling cost. Commercial scanners are priced out of reach for many local organisations, and free checkers scan one site at a time. The open-source prototype removes the cost argument: any organisation can scan itself with three commands and no licence.

The failure chain the study interrupts is straightforward: missing header, to enlarged attack surface (XSS, clickjacking, downgrade attacks), to incident, to direct financial and reputational loss — losses that fall

hardest on citizens who trust public and financial institutions online. Measuring the problem is the precondition for fixing it: without a baseline, neither remediation effort nor policy can be evaluated.

9. Hypotheses

The study will evaluate three working hypotheses, each stated before data collection and judged against the scan results using pre-defined decision rules.

- H1: The majority of sampled sites are missing at least two of the six recommended headers. Decision rule: supported if more than 50% of reachable sites have two or more headers classified as missing. Rationale: prior measurement studies consistently report multi-header absence outside the very top of the web (Lavrenovs & Rubio Melón, 2018).
- H2: Financial and government sites achieve higher average header scores than educational and commercial sites. Decision rule: supported if the combined finance-plus-government mean score exceeds the combined education-plus-commercial mean. Rationale: regulated sectors face compliance pressure and larger security budgets.
- H3: CSP is the most commonly missing or weakly configured header among the six. Decision rule: supported if CSP has the lowest correct-configuration rate across the sample. Rationale: CSP is the most complex header to configure correctly, and prior work shows most deployed policies are ineffective (Weichselbaum et al., 2017).

Hypothesis testing here is descriptive-comparative: each verdict will be reported with its supporting statistic, and the analysis file will preserve the numbers so readers can re-derive every conclusion.

10. Prototype

To demonstrate feasibility and validate the methodology before the full study, a working prototype of the complete pipeline will be built as an open-source Python project. The prototype doubles as the study's instrument and its proof of concept.

Architecture. The pipeline will consist of three stages. The scanner stage (`scan.py`) reads the site list and fetches headers concurrently, writing a raw CSV in which each row is one site and each column one recorded header, plus scan timestamps and error classification. The analysis stage (`analyze.py`) reads the raw CSV, applies the published classification rules to grade each of the six headers per site, computes the 0–100 scores, aggregates per-header and per-category statistics, runs the chi-square tests, and emits a structured JSON results file. The reporting stage (`report.py`) renders a human-readable summary document and four charts: header adoption, regional comparison, category comparison, and the score distribution.

Verification of the prototype. The prototype will be validated in three ways: a smoke-test mode that scans a five-site subset end-to-end; unit checks that the classification rules produce the expected verdict for known-good, known-weak and missing header values; and a full-sample dry run confirming that runtime for 100 sites stays within a single scan window of a few minutes, with per-site timestamps recorded for reproducibility.

From prototype to study. The prototype already demonstrates that the method is technically feasible and safe (passive GET requests only). For the study it will be hardened with: the full, documented site list; expanded classification rules reviewed against the standards; and published raw and processed datasets. After submission, the same pipeline supports longitudinal re-scanning, turning a one-off class project into a

durable, repeatable measurement capability for Mozambique's web — an outcome that directly serves the reproducibility objective of the study.

References

- Calzavara, S., Rabitti, A., Roth, S., & Backes, M. (2020). A tale of two headers: A formal analysis of inconsistent click-jacking protection on the web. In *Proceedings of the 29th USENIX Security Symposium* (pp. 1575–1592). USENIX Association.
- Helme, S. (2024). *SecurityHeaders.com — Security report*. Retrieved from <https://securityheaders.com>
- Hodges, J., Jackson, C., & Barth, A. (2012). *HTTP Strict Transport Security (HSTS)* (RFC 6797). Internet Engineering Task Force. <https://doi.org/10.17487/RFC6797>
- HTTP Archive. (2022). *Web Almanac 2022: Security chapter*. Retrieved from <https://almanac.httparchive.org/en/2022/security>
- International Telecommunication Union. (2024). *Global Cybersecurity Index 2024* (5th ed.). Geneva: ITU Publications.
- Lavrenovs, A., & Rubio Melón, F. J. (2018). HTTP security headers analysis of top one million websites. In *Proceedings of the 10th IFIP International Conference on New Technologies, Mobility and Security (NTMS)* (pp. 1–5). IEEE.
- MDN Web Docs. (2025). *Content Security Policy (CSP)*. Mozilla. Retrieved from <https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>
- OWASP Foundation. (2025). *OWASP Secure Headers Project*. Retrieved from <https://owasp.org/www-project-secure-headers/>
- Singer, A., & Fielding, R. (2022). *HTTP Semantics* (RFC 9110). Internet Engineering Task Force. <https://doi.org/10.17487/RFC9110>
- Weichselbaum, L., Spagnuolo, M., Lekies, S., & Janc, A. (2017). CSP is dead, long live CSP! On the insecurity of whitelists and the future of Content Security Policy. In *Proceedings of the 2017 ACM Asia Conference on Computer and Communications Security (AsiaCCS)* (pp. 511–522). ACM.